

Sample Finals Solutions:

Message Integrity Question 1:

1a. [4 pts] As stated above, how would Alice generate the digital signature?

Alice would take a hash of the message, and encrypt it using her private certificates.

1b. [4 pts] How can Trudy (who is evil) take advantage of this system to get herself more money?

The message can be captured and resent by Trudy to the bank. Since the digital signature is valid, the bank would transfer the funds multiple times.

1c. [4 pts] How can the communication be modified to prevent this attack?

A nonce can be added to the communication in the following manner:

Alice -> Bank: Hello

Bank -> Alice: Here's a nonce R

Alice -> Bank: "transfer \$1000 to Trudy" + R + Encrypt(hash("transfer \$1000 to Trudy" + R))
where the encryption uses the private cert.

Bank -> Alice: Success

In this scenario, Trudy won't be able to perform a replay attack.

Message Integrity Question 2:

No solution provided

SSL/TLS Question 1:

1a. [4 pts] Suppose that in the SSL Full Handshake, as shown, the Finished messages do not contain a checksum of all previous handshake messages. Describe two ways that an attacker can take advantage of this flaw.

Although the attacker can MITM the connection, the Attacker still cannot see the data as the attacker cannot forge a valid certificate, but he can change some messages:

1. Version rollback attack – force the client to offer an earlier version of SSL which has more vulnerabilities
2. CipherSpec rollback – force the client to offer weaker version of cipherspecs so it can be broken easier.

1b. [4 pts] Describe each algorithm of this ciphersuite its purpose in SSL/TLS:

TLS_DHE_RSA_WITH_AES_128_CBC_SHA

DHE – client/server uses DH to exchange keys for each session.

RSA – the authentication protocol, used with DHE

AES_128_CBC – uses AES 128-bit keys in CBC mode for bulk encryption

SHA – SHA is used as the integrity

1c. [2 pts] What's the primary security difference between these two ciphersuites:

TLS_DHE_RSA_WITH_AES_128_CBC_SHA and

TLS_DH_RSA_WITH_AES_128_CBC_SHA

The E in the first protocol stands for ephemeral, which means new DH keys are exchanged for each session. If the session keys are compromised, only the data for that session is lost. This provides what's called Perfect Forward Security.

SSL/TLS Question 2:

2a. [3 pts] What messages are hashed by each of the Finished messages in the SSL Full Handshake? Be specific.

The Finished messages has all the previous handshake messages. For the Finished message in (8), the messages (1)-(6) are hashed. For the Finished message in (10), the messages (1)-(6) and (8) are hashed. The ChangeCipherSpec is not hashed because it's not a handshake message for the purpose of forcing the following message, the Finished message, to be sent in a new packet.

2b. [3 pts] When is the first encrypted message sent from each side in the SSL Full Handshake? The Finished message is the first encrypted message sent from each side.

2c. [3 pts] What is the SSL Abbreviated Handshake and how are the messages different from the SSL Full Handshake?

The SSL Abbreviated Handshake is used for resumption of SSL connections. The client sends "session id" from the previous session. If the server remembers it, the server will immediately send (9) ChangeCipherSpec and (10) Finished after ServerHello (2). Then the client will agree by sending (7) ChangeCipherSpec and (8) Finished.

2d. [3 pts] Why should the TLS_ECDH_ECDSA_WITH_AES_256_CBC_SHA ciphersuite, which is a TLS 1.2 ciphersuite, not be used anymore?

ECDH does not have to property of Perfect Forward Security. Also accepted for 1 point is that SHA is somewhat broken and should be avoided.

2e. [3 pts] If an attacker sent a TCP RST message to reset a TLS connection, does TLS know that the TCP connection was attacked? How?

Yes, as TLS expects a close_notify TLS message before the TCP connection ends. If the TCP RST comes before close_notify, then there is something wrong, such as an attacker.

PKI/TLS Question 1:

1a. [4 pts] If amazon.com always uses the ciphersuite

TLS_RSA_WITH_AES_256_CBC_SHA, are prior encrypted connections protected after Trudy steals the key? Explain why.

No, prior connections are not protected because this ciphersuite does not have the property of perfect forward security. Each time a TLS connection is established, the same RSA key is used for key exchange and authentication, therefore when the TLS private keys are lost, all prior connections can be decrypted.

1b. [4 pts] How can Trudy use the stolen private key to MITM a TLS connection and see encrypted data between a user and amazon.com? Explain why this cannot be easily done without the private key.

With the private key, Trudy can successfully impersonate amazon.com without causing browser errors stating that certificates are bad. This cannot be done without the private keys because the browser is supposed to detect any errors during certificate validation.

1c. [2 pts] Is it possible for a CA to issue more than one TLS certificate for amazon.com? Explain why or why not.

Yes, it's possible because issuing certificates is not a technical limitation, and a CA is free to (and commonly does) issue multiple TLS certificates for a single domain name.

1d. [4 pts] Suppose a root CA was vulnerable to Heartbleed and lost its private keys. What can a user do to protect him or herself from being eavesdropped on?

Multiple correct answers.

1. User can remove the CA from the browser or OS certificate list.
2. Avoid websites with compromised certificates (that's pretty hard to do).
3. Change passwords (to avoid further compromise).

PKI/TLS Question 2:

a. [3 pts] Explain how Alice would mutually authenticate an ACME server using her PKI certificates.

There are multiple correct ways to answer this question. In order to perform mutual authentication, both Alice and ACME server must authenticate to each other, like so:

Alice -> ACME: Hello, and here's a nonce R1

ACME -> Alice: Encrypt(R1) with private key, and here's another nonce R2

Alice -> ACME: Encrypt(R2) with private key

[Bi-directional communications begin]

A few assumptions were made for this to work out, including that Alice's laptop and ACME's server already stored the ACME CA public cert.

Sidenote: One of the most secure methods to store PKI private certs is by using a hardware-based solution, such as the Intel Trusted Platform Module (TPM), which is available on many Intel CPUs. Private keys are generated by the chip and cannot be easily removed.

b. [3 pts] How does ACME and Alice know that each other's certificate is valid?

Both ACME and Alice needed to be able to verify the authenticity of certificate by checking the chain of trust and ensuring that all fields are valid. After ensuring the certificate is valid, each will also need to verify the Subject Common Name (CN) of the other entity. For Alice, she would need to have her name or other unique identifying information on her public cert. For the server, it would have the server's address/IP/name on the cert.

c. [3 pts] If Alice used her PKI certificates for encrypted communications to Bob, would ACME be able to read the encrypted conversation? Explain.

Absolutely, because both Alice and Bob needs to trust the ACME CA, and the ACME CA will be able to generate any certificates that are authentic to both Alice and Bob. ACME CA does not actually have the certs, but can generate a new one that looks just like it and can use to MITM the connection. There's a caveat: if Alice and Bob were able to exchange the "fingerprint" of each other's public certificate in some manner before hand, then they would be able to see that if the certificates are real.

d. [3 pts] Trudy (who is evil) also worked at ACME corporation and has valid PKI certificates to authenticate into the ACME network. In what instances would Trudy be able to read the encrypted communication between Alice and Bob? Explain.

If everything works the way it's supposed to be working, then there's not much that Trudy can do.

SSL/TLS Question 3:

2a. [6 pts] The above diagram shows the SSL Record Layer Operations. Describe what each number (1) to (6) is referring to.

- (1) Application data. Shows the data from the view of the application.
- (2) SSL fragments to a 16Kb fragments, which is the max size for SSL packets.
- (3) Compression, which isn't used due to numerous vulnerabilities.
- (4) HMAC of the plaintext is appended to the packet.

(5) The entire packet (plaintext and HMAC) are encrypted.

(6) Header information is added to the packet.

Note: (3), (4), and (5) can be summarized as “HMAC then Encrypt”

2b. [6 pts] Select the ciphersuites that should not be support anymore today and explain why.

Explanation required for credit.

(1) TLS_RSA_WITH_RC4_128_SHA – should not be used because it does not have Perfect Forward Security and RC4 is broken.

(2) TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 – good ciphersuite

(3) TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256 – good ciphersuite

(4) TLS_ECDHE_ECDSA_WITH_RC4_128_SHA – RC4 should not be used anymore

(5) TLS_DH_RSA_WITH_AES_128_CBC_SHA – No PFS, and it uses SHA1, which is somewhat broken.

PKI /TLS Question 3:

1a. [8 pts] If you were the security engineer for a website, explain for each of the following ciphersuites if you recommend to the administrator to keep them enabled or disabled, and state your reason for each. For disabled, state all the reasons why the ciphersuite should be disabled:

(1) SSL_DHE_RSA_EXPORT_WITH_DES40_CBC_SHA - disable. Export ciphers (RSA_EXPORT) are very weak. DES40 is broken and SHA1 shouldn't be used anymore.

(2) TLS_RSA_WITH_AES_128_CBC_SHA256 – disable. No PFS.

(3) SSL_DHE_RSA_WITH_3DES_EDE_CBC_SHA – disable. 3DES EDE is very weak. SHA1 shouldn't be used anymore

(4) TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 – enable. This cipher has PFS, good symmetric algorithm, and good hashing function.

(5) TLS_ECDH_RSA_WITH_AES_256_CBC_SHA384 - disable. No PFS.

1b. [4 pts] Suppose a TLS connection is using the ciphersuite

TLS_DHE_RSA_WITH_AES_128_CBC_SHA256. How does TLS ensure that each message has a different ciphertext even when the plaintext message is the same?

“Mode of operation” CBC ensures there's a separate IV for each message.

2. TLS. No solution provided

PKI /TLS Question 4: No solution provided

LECTURE 8 – FIREWALLS

IPTables Question 1:

Interior Firewall	
Set a default policy to drop all packets. Or, you can have a catch all at the end of your rules.	<pre>iptables -P INPUT DROP iptables -P OUTPUT DROP iptables -P FORWARD DROP</pre>
Rules for 3a.	<pre>iptables -A OUTPUT -o eth0 -d 10.10.111.10 -p tcp --dport 6514 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A INPUT -i eth0 -s 10.10.111.10 -p tcp --sport 6514 -m conntrack --ctstate ESTABLISHED -j ACCEPT iptables -A FORWARD -i eth1 -s 10.30.111.2 -o eth0 -d 10.10.111.10 -p tcp --dport 6514 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A FORWARD -o eth1 -d 10.30.111.2 -i eth0 -s 10.10.111.10 -p tcp --sport 6514 -m conntrack --ctstate ESTABLISHED -j ACCEPT</pre>
Rules for 3b. Not needed after answering 3c.	<pre>iptables -A FORWARD -i eth0 -s 10.10.111.20 -o eth1 -d ! 10.20.111.0/24 -p tcp --dport 80 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A FORWARD -o eth0 -d 10.10.111.20 -i eth1 -s ! 10.20.111.0/24 -p tcp --sport 80 -m conntrack --ctstate ESTABLISHED -j ACCEPT</pre>
Rules for 3c. Supersedes the rule for 3b.	<pre>iptables -A FORWARD -i eth0 -s 10.10.111.0/24 -o eth1 -d 10.20.111.0/24 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A FORWARD -o eth0 -d 10.10.111.0/24 -i eth1 -s 10.20.111.0/24 -m conntrack --ctstate ESTABLISHED -j ACCEPT</pre>

Exterior Firewall	
Set a default policy to drop all packets.	<pre>iptables -P INPUT DROP iptables -P OUTPUT DROP iptables -P FORWARD DROP</pre>

Rules for 3a.	<pre>iptables -A OUTPUT -o eth0 -d 10.10.111.10 -p tcp --dport 6514 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A INPUT -i eth0 -s 10.10.111.10 -p tcp --sport 6514 -m conntrack --ctstate ESTABLISHED -j ACCEPT</pre>
Rules for 3b.	<pre>iptables -A FORWARD -i eth0 -s 10.10.111.20 -o eth1 -p tcp --dport 80 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A FORWARD -o eth0 -d 10.10.111.20 -i eth1 -p tcp --sport 80 -m conntrack --ctstate ESTABLISHED -j ACCEPT</pre>
Rules for 3c.	<pre>iptables -A FORWARD -i eth1 -o eth0 -d 10.20.111.3 -p tcp --dport 80 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A FORWARD -i eth1 -o eth0 -d 10.20.111.4 -p tcp --dport 22 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A FORWARD -i eth1 -o eth0 -d 10.20.111.5 -p udp --dport 53 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A FORWARD -o eth0 -i eth1 -m conntrack --ctstate ESTABLISHED -j ACCEPT</pre>

Can have a rule just for established connections on the Interior FW:

```
iptables -A INPUT -m conntrack --ctstate ESTABLISHED -j ACCEPT
```

IPTables Question 2:

Interior Firewall	
Set a default policy to drop all packets.	<pre>iptables -P INPUT DROP iptables -P OUTPUT DROP iptables -P FORWARD DROP</pre>
Rules for 3a.	<pre>iptables -A FORWARD -p icmp --icmp-type echo-request -d 10.66.0.2 -i eth0 -o eth1 -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT iptables -A FORWARD -p icmp --icmp-type echo-reply -s 10.66.0.2 -o eth0 -i eth1 -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT iptables -A OUTPUT -p icmp --icmp-type echo-request -d 10.66.0.2 -o eth1 -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT iptables -A INPUT -p icmp --icmp-type echo-reply -s 10.66.0.2 -i eth1 -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT</pre>
Rules for 3b.	<pre>iptables -A FORWARD -i eth1 -s 10.66.0.3 -o eth0 -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT iptables -A FORWARD -o eth1 -d 10.66.0.3 -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT iptables -A INPUT -s 10.66.0.3 -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT iptables -A OUTPUT -d 10.66.0.3 -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT</pre>
Rules for 3c.	<pre>iptables -A FORWARD -i eth0 -s 10.20.111.3 -o eth1 -d 10.66.0.2 -p TCP --dport 80 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A FORWARD -i eth0 -s 10.20.111.3 -o eth1 -d 10.66.0.2 -p TCP --dport 443 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A FORWARD -o eth0 -d 10.20.111.3 -i eth1 -s 10.66.0.2 -p TCP --sport 80 -m conntrack --ctstate ESTABLISHED -j ACCEPT iptables -A FORWARD -o eth0 -d 10.20.111.3 -i eth1 -s 10.66.0.2 -p TCP --sport 443 -m conntrack --ctstate ESTABLISHED -j ACCEPT</pre>

Exterior Firewall	
Set a default policy to drop all packets.	<pre>iptables -P INPUT DROP iptables -P OUTPUT DROP iptables -P FORWARD DROP</pre>
Rules for 3a.	Exactly the same as Interior Firewall 3a.
Rules for 3b.	<pre>iptables -A FORWARD -i eth1 -s 10.66.0.3 -o eth0 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A FORWARD -o eth1 -d 10.66.0.3 -m conntrack --ctstate ESTABLISHED -j ACCEPT iptables -A FORWARD -i eth0 -s 10.10.111.4 -o eth1 -d 10.66.0.3 -p TCP --dport 22 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A INPUT -s 10.66.0.3 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A OUTPUT -d 10.66.0.3 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT</pre>
Rules for 3c.	<pre>iptables -A FORWARD -i eth0 -s 10.20.111.3 -o eth1 -d 10.66.0.2 -p TCP --dport 80 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A FORWARD -i eth0 -s 10.20.111.3 -o eth1 -d 10.66.0.2 -p TCP --dport 443 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A FORWARD -o eth0 -d 10.20.111.3 -i eth1 -s 10.66.0.2 -p TCP --sport 80 -m conntrack --ctstate ESTABLISHED -j ACCEPT iptables -A FORWARD -o eth0 -d 10.20.111.3 -i eth1 -s 10.66.0.2 -p TCP --sport 443 -m conntrack --ctstate ESTABLISHED -j ACCEPT iptables -A FORWARD -i eth0 -s 10.10.111.3 -o eth1 -d 10.66.0.2 -p TCP --dport 80 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A FORWARD -i eth0 -s 10.10.111.3 -o eth1 -d 10.66.0.2 -p TCP --dport 443 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT iptables -A FORWARD -o eth0 -d 10.10.111.3 -i eth1 -s 10.66.0.2 -p TCP --sport 80 -m conntrack --ctstate ESTABLISHED -j ACCEPT iptables -A FORWARD -o eth0 -d 10.10.111.3 -i eth1 -s 10.66.0.2 -p TCP --sport 443 -m conntrack --ctstate ESTABLISHED -j ACCEPT</pre>

IPTables Question 3:

a. [3 pts] Both the Firewall and HTTP Proxy Gateway shall drop all other packets not specified.

On both devices:

`iptables -P INPUT DROP`

`iptables -P OUTPUT DROP`

`iptables -P FORWARD DROP`

b. [10 pts] All HTTP (80) and HTTPS (443) traffic initiated from the Internal Network 10.10.111.0/24 must go through the HTTP Proxy Gateway (10.20.111.20) in order to access the Internet. Only the HTTP Proxy Gateway is allowed access the Internet.

Note: The HTTP Proxy Gateway recreates TCP connections to increase security.

Firewall:

`-A FORWARD -i eth0 -o eth1 -s 10.10.111.0/24 -d 10.20.111.20 -p tcp -dports 80,443 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT`

`-A FORWARD -o eth0 -i eth1 -d 10.10.111.0/24 -s 10.20.111.20 -p tcp -sports 80,443 -m conntrack --ctstate ESTABLISHED -j ACCEPT`

`-A FORWARD -i eth1 -o eth2 -s 10.20.111.20 -p tcp -dports 80,443 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT`

`-A FORWARD -o eth1 -i eth2 -d 10.20.111.20 -p tcp -sports 80,443 -m conntrack --ctstate ESTABLISHED -j ACCEPT`

HTTP Proxy Gateway:

`-A INPUT -s 10.10.111.0/24 -p tcp -dports 80,443 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT`

`-A OUTPUT -d 10.10.111.0/24 -p tcp -sports 80,443 -m conntrack --ctstate ESTABLISHED -j ACCEPT`

`-A OUTPUT -d 10.10.111.0/24 -m conntrack --ctstate NEW -j DROP -A OUTPUT -d 10.20.111.0/24 -m conntrack --ctstate NEW -j DROP`

`-A OUTPUT -p tcp -dports 80,443 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT`

`-A INPUT -p tcp -sports 80,443 -m conntrack --ctstate ESTABLISHED -j ACCEPT`

c. [5 pts] The Firewall, HTTP Proxy Gateway, and Web Server will allow pings only from the administrator on 10.10.111.103.

Firewall:

`-A INPUT -i eth0 -s 10.10.111.103 -p icmp --icmp-type echo-request -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT`

`-A OUTPUT -o eth0 -d 10.10.111.103 -p icmp --icmp-type echo-reply -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT`

`-A FORWARD -i eth0 -o eth1 -s 10.10.111.103 -p icmp --icmp-type echo-request -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT`

`-A FORWARD -o eth0 -i eth1 -d 10.10.111.103 -p icmp --icmp-type echo-reply -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT`

HTTP Proxy Gateway:

`-A INPUT -s 10.10.111.103 -p icmp --icmp-type echo-request -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT`

`-A OUTPUT -d 10.10.111.103 -p icmp --icmp-type echo-reply -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT`

d. [4 pts] The Internet can initiate connections to the Web Server on TCP port 80 and 443.
Firewall:

```
-A FORWARD -i eth2 -o eth1 -d 10.20.111.30 -p tcp -dports 80,443 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT
```

```
-A FORWARD -o eth2 -i eth1 -s 10.20.111.30 -p tcp -sports 80,443 -m conntrack --ctstate ESTABLISHED -j ACCEPT
```

IPTables Question 4:

4a. [3 pts] Both Firewalls shall drop all other packets not specified.

On both devices:

```
-P INPUT DROP
```

```
-P OUTPUT DROP
```

```
-P FORWARD DROP
```

4b. [10 pts] The DHCP Server provides DHCP addresses to the Interior Firewall and to the clients on the Wireless Network.

Note: DHCP Discovery and Requests are from UDP source port 68 to destination port 67, and Offers and ACKs are the opposite.

Note 2: Assume iptables works with DHCP.

Note: iptables doesn't work with DHCP as iptables cannot listen on 0.0.0.0, but we assume it works for this exercise.

Interior firewall:

```
-A FORWARD -i eth1 -o eth0 -p udp --sport 68 --dport 67 -m conntrack --ctstate NEW -j ACCEPT
```

```
-A FORWARD -s 10.10.111.5 -i eth0 -o eth1 -p udp --sport 67 --dport 68 -m conntrack --ctstate RELATED -j ACCEPT
```

```
-A OUTPUT -o eth0 -p udp --sport 68 --dport 67 -m conntrack --ctstate NEW -j ACCEPT
```

```
-A INPUT -s 10.10.111.5 -i eth0 -p udp --sport 67 --dport 68 -m conntrack --ctstate RELATED -j ACCEPT
```

Exterior firewall: None.

4c. [4 pts] All HTTP (80) and HTTPS (443) traffic initiated from the Internal Network 10.10.111.0/24 must go through the HTTP Proxy Gateway (10.20.111.20) in order to access the Internet. Only the HTTP Proxy Gateway is allowed access the Internet.

Interior firewall:

```
-A FORWARD -i eth1 -o eth0 -d 10.10.111.4 -p tcp --destination-ports 80,443 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT
```

```
-A FORWARD -o eth1 -i eth0 -s 10.10.111.4 -p tcp --source-ports 80,443 -m conntrack --ctstate ESTABLISHED -j ACCEPT
```

Exterior firewall:

```
-A FORWARD -i eth0 -o eth1 -s 10.10.111.4 -p tcp --destination-ports 80,443 -m conntrack --ctstate NEW,ESTABLISHED -j ACCEPT
```

```
-A FORWARD -o eth0 -i eth1 -d 10.10.111.4 -p tcp --source-ports 80,443 -m conntrack --ctstate ESTABLISHED -j ACCEPT
```

4d. [5 pts] The administrator (10.10.111.3) can initiate pings to anywhere on the network.

Interior firewall:


```
-A FORWARD -i eth0 -o eth1 -s 10.10.111.3 -p icmp --icmp-type echo-request -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT
-A FORWARD -o eth0 -i eth1 -d 10.10.111.3 -p icmp --icmp-type echo-reply -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
-A INPUT -s 10.10.111.3 -p icmp --icmp-type echo-request -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT
-A OUTPUT -d 10.10.111.3 -p icmp --icmp-type echo-reply -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
```

Exterior firewall:

```
-A INPUT -s 10.10.111.3 -p icmp --icmp-type echo-request -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT
-A OUTPUT -d 10.10.111.3 -p icmp --icmp-type echo-reply -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
```

IPTables Question 5:

Both firewalls need a default policy to drop all packets that are not explicitly allowed, or a rule to drop all packets at the end:

```
-A INPUT -P DROP
-A OUTPUT -P DROP
-A FORWARD -P DROP
```

4a. [6 pts] All host must respond to a ping from the Administrator, including the firewalls.

Firewall A

```
-A FORWARD -i eth1 -o eth0 -s 10.30.111.20 -p icmp --icmp-type echo-request -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT
-A FORWARD -i eth0 -o eth1 -d 10.30.111.20 -p icmp --icmp-type echo-reply -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
-A INPUT -i eth1 -s 10.30.111.20 -p icmp --icmp-type echo-request -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT
-A OUTPUT -o eth1 -d 10.30.111.20 -p icmp --icmp-type echo-reply -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
```

Firewall B

Same as Firewall A

4b. [5 pts] The SIEM shall accept syslog (TCP 6514) and netflow (unidirectional UDP 4432) from all hosts, including the firewalls.

Firewall A

```
-A FORWARD -i eth1 -o eth0 -d 10.20.111.10 -p tcp --dport 6514 -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT
-A FORWARD -i eth0 -o eth1 -s 10.20.111.10 -p tcp --sport 6514 -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
-A OUTPUT -o eth0 -d 10.20.111.10 -p tcp --dport 6514 -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT
-A INPUT -i eth0 -s 10.20.111.10 -p tcp --sport 6514 -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
-A OUTPUT -o eth0 -d 10.20.111.10 -p udp --dport 4432 -j ACCEPT
-A FORWARD -i eth1 -o eth0 -d 10.20.111.10 -p udp --dport 4432 -j ACCEPT
```

Firewall B

```

-A FORWARD -i eth0 -o eth1 -d 10.20.111.10 -p tcp --dport 6514 -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT
-A FORWARD -i eth1 -o eth0 -s 10.20.111.10 -p tcp --sport 6514 -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
-A OUTPUT -o eth1 -d 10.20.111.10 -p tcp --dport 6514 -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT
-A INPUT -i eth1 -s 10.20.111.10 -p tcp --sport 6514 -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
-A FORWARD -i eth0 -o eth1 -d 10.20.111.10 -p udp --dport 4432 -j ACCEPT
-A OUTPUT -o eth1 -d 10.20.111.10 -p udp --dport 4432 -j ACCEPT

```

4c. [4 pts] The hosts in the Guest Network can only initiate connection to the Web Server (10.20.111.20).

Firewall A

None.

Firewall B

```

-A FORWARD -i eth0 -o eth1 -s 10.10.111.0/24 -d 10.20.111.20 -p tcp --dports 80,443 -m conntrack --ctstate NEW,ESTABLISHED,RELATED -j ACCEPT iptables
-A FORWARD -i eth1 -o eth0 -s 10.20.111.20 -d 10.10.111.0/24 -p tcp --sport 80,443 -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT

```

4d. [10 pts] Firewall B provides DHCP to the Guest Network. Protect against Rogue Server attacks. Note: DHCP Discovery and Requests are from UDP source port 68 to destination port 67, and Offers and ACKs are the opposite.

Note 2: Assume iptables works with DHCP.

Firewall A

None.

Firewall B

```

-A INPUT -i eth0 -p udp --sport 68 --dport 67 -j ACCEPT -A OUTPUT -i eth0 -s 10.10.111.1 -p udp --sport 67 --dport 68 -j ACCEPT

```

IPTables Question 5: No solution provided

DHCP Question 1:

5a. [6 pts] What would the Attacker have to do using the DHCP protocol to set up a MITM attack between the Client and the Internet? In other words, to have access to all the traffic going to/from the Internet and to/from the Client?

When the Client enters the network, it makes a DHCP Discover (which is a broadcast), the Attacker will reply back with a DHCP Offer set with the Attacker's IP as the gateway. Usually, the Attacker will need to be faster than the DHCP Server.

In the case of this diagram where the Client is already connected, the Attacker can wait for the Client to go offline or the DHCP lease to run out. In either case, the Client will eventually send a DHCP Request (Broadcast). The Attacker will reply with a DHCP ACK with the Attacker's IP as the gateway.

Another correct answer is: The Attacker can reply with a DHCP NACK (Negative ACK), and thus the Client will need to do a DHCP Discover again; or the Attacker can take the Client offline with an exploit or DOS.

5b. [3 pts] What would the Attacker have to do using the DHCP protocol to deny any clients from joining the network?

DHCP Exhaustion Attack by performing DHCP Requests until there are no more addresses. This is done by not changing the Attacker's MAC address and only changing the Client HW Address in the DHCP packet.

5c. [6 pts] Describe in detail three ways to mitigate these two attacks.

1. Block port 68 on the interfaces that don't have the DHCP server. This will make the Attacker not able to send DHCP Offer and DHCP ACK.
2. Enable DHCP Snooping which allows an interface to be set as Trusted or Untrusted. Untrusted links will not be allowed to send DHCP Offer/ACK packets.
3. Enable DHCP Snooping which checks if the MAC address matches the Client HW Address.

LECTURE 8 – LAYER 2 SECURITY

Layer 2 Security Question 1:

4a. [5 pts] Using only layer two protocols, describe the step-by-step process in detail in which Trudy successfully becomes the MITM between Alice and amazon.com without disruption any of Bob's network connections. Specify IP/MAC address when necessary.

- (1) Trudy will need to wait until the ARP cache entry expires, or DOS Alice until the ARP cache entry expires.
- (2) Trudy will send ARP Reply to the Router saying that 10.10.10.3 is associated with MAC T.
- (3) Trudy will send an ARP Reply to Alice saying that 10.10.10.2 is associated with MAC T.
- (4) Trudy will bridge the connection, and is now the MITM.

4b. [4 pts] Explain how SSLStrip works to allow Trudy to view the supposedly encrypted TLS connection between Alice and amazon.com.

SSLStrip sits in between Alice and amazon.com. When Alice goes to the encrypted amazon.com website, SSLStrip will establish a TLS connection for amazon.com for Alice, but will send the decrypted page to Alice. This allows SSLStrip to see the encrypted data without the correct private keys.

4c. [4 pts] How does Dynamic ARP Inspection (DAI) know if an ARP is being spoofed and needs to be dropped?

First, DHCP Snooping needs to be enabled, which creates the DHCP Snooping Binding Table. Entries are added to the table by capturing valid DHCP traffic. DAI will check each ARP Reply to ensure that the source MAC and IP matches what's in the table.

Layer 2 Security Question 2:

5a. [6 pts] Using only ARP packets, describe the step-by-step process in detail in which Trudy successfully becomes the MITM between Alice and amazon.com:

- (1) by spoofing the ARP table; and (2) by overloading the CAM table on the switch.
- Describe the details of the ARP packets in detail.

(1) In the ARP spoofing attack, the attacker sends an ARP packet claiming to have the MAC address of the Alice, and another ARP packet claiming to have the MAC address of the Router. This results in all traffic between the Router and Alice being diverted via Trudy.

(2) In the CAM attack, the attacker floods the CAM table with random ARP reply packets ensuring that the CAM table is filled and the switch can no longer learn any new MAC addresses. When the CAM table overflows, the switch acts as a hub.

5b. [2 pts] If Trudy uses SSLStrip, what will Alice see from her perspective when she logs into amazon.com?

Alice will be able to see the same homepage of Amazon.com. However this would be a plain HTTP page with the TLS layer security stripped off as the traffic is now flowing through Trudy's machine. All the bidirectional traffic is routed via Trudy's machine without amazon.com or Alice ever knowing.

5c. [4 pts] Describe how IP Spoof Guard (IPSG) works and what information it would use to stop this attack.

IPSG uses the DHCP snooping binding table information to check every IP packet in ensuring that the IP address coming from the interface matches with that of the information collected by DHCP Snooping.

Layer 2 Security Question 3:

5a. [4 pts] If the Attacker can only send one ARP packet and nothing else, what is the single ARP packet that will allow the Attacker to eavesdrop on as much traffic as possible? Describe the ARP packet in detail and explain why.

Gratuitous ARP Request or Reply stating that the Attacker is the Router (saying it has IP 10.10.111.1 and MAC R) would probably capture any new traffic originating from the Clients.

5b. [4 pts] Suppose that the Attacker knows that the Client with MAC B, which already has a DHCP IP address, will be renewing its lease soon. How can the Attacker be the MITM between Client B and the Router R using only the DHCP protocol?

When the Client will eventually send a DHCP Request (Broadcast). The Attacker will reply with a DHCP ACK with the Attacker's IP as the gateway

5c. [6 pts] Describe in detail three ways to mitigate these two attacks.

(1) DHCP Snooping – a feature that allows the switch to monitor all DHCP traffic. The interface for the Attacker would be set to “untrusted,” so the attacker won't be able to send Offers/ACKs/NAKs.

(2) Block port 68 on the interfaces that don't have the DHCP server. This will make the Attacker not able to send DHCP Offer and DHCP ACK.

(3) Enable DHCP Snooping which checks if the MAC address matches the Client HW Address.

DHCP Question 2: No solution provided

LECTURE 9 – WIRELESS SECURITY

ACME Corporation has upgraded their WiFi network to WPA2-AES network for employees only. The WPA2 AP is configured with a Pre-Shared Key. Suppose Trudy is parked outside ACME.

6a. [4 pts] What information can Trudy obtain from just sniffing the wireless traffic of ACME corporation? **With WPA2, the MAC address (source, destination, and router) would be visible.**

TRUE/FALSE. No explanations needed.

8a. In TLS, compression is mandatory because compression thwarts many attacks. **False- actually compression is not used anymore due to numerous attacks based on compression.**

8e. Stateless firewalls are typically faster than stateful firewalls. **True- stateless firewalls are usually hardware devices.**

8b. In TLS, the server chooses the ciphersuite to use. – **True.**

8c. Web servers (e.g., amazon.com) is only allowed to have one TLS certificate at a time. **False. Anyone and anything can technically have an unlimited number of certificates.**

8e. A DHCP Server only looks at the MAC address in the Ethernet header. – **False. It looks at CHADDR**

Remaining questions: No solution provided